Secure Architecture and Threat Modeling Report

University Management System (Option D)

By Fowzi Ali

L1-Cyber Security: Theory, Tools

Date: 2/28/2026

System Overview

The University Management System is a web-based system that works over the internet. It allows students, teachers, and university administration in a typical Pakistani university to access academic, financial, health, and administrative services from anywhere (home, campus, or mobile phone).

The system does not depend on any specific cloud provider. It is fully accessible from the internet and is designed to handle both:

- **External threats** (hackers on the internet)
- **Internal threats** (students or staff who misuse their access)

1. Application Components

Student Portal:
A website that works on computers and mobile phones. Students can use it to access:

- Learning Management System (LMS)
- Attendance
- Fee details
- Grades
- Alumni portal
- Wellness services
- Library system

Faculty Portal:
A website for teachers to access:

- LMS
- Attendance
- Salary information
- Their courses
- Library
- Wellness services

Admin / Registrar Portal:
A restricted website used only by administration and registrar staff for full system control and management.

API Gateway:
The main entry point for all requests. It:

- Checks user identity (authentication)
- Controls request limits

- Sends requests to the correct backend service

Backend Services:
Internal systems that handle all main functions such as:

- LMS
- Attendance
- Fees
- Grades
- Library
- Wellness
- Salary
- Alumni
- Job integration

Data Storage:
Separate databases for different types of data:

- Student & Personal Database
- Academic Database
- Financial Database
- Wellness Database

Admin Access Paths:
Special secure access channels used only by registrar and admin staff.

2. Users and Roles (Actors)

Students:
Regular users who access academic and personal services through the Student Portal.

Faculty:
Internal users who manage courses, attendance, salary, and wellness using the Faculty Portal.

Administration / Registrar:
Highly privileged users who have full system control and oversight.

External Systems:

- Identity Provider (for login and authentication)
- Job Portals / Companies (to show job opportunities to students)

Threat Actors:
The system considers:

- External attackers trying to break in

- Malicious students or staff misusing their authorized access

3. Data Types Handled

The system stores and processes:

- Personal information (PII)
- Login details and session tokens
- Academic records (grades, attendance, courses, assignments)
- Financial information (fees and salaries)
- Sensitive health and wellness data
- Alumni and library records
- Job-related information
- System and audit logs

4. External Dependencies

Central Identity Provider:
Used for single sign-on and user authentication.

External Job Portals / Company Systems:
Used to display job postings inside the university portal for graduating students.

5. Trust Boundaries

The system has several security layers where the level of trust changes:

Internet to Portals:
Separates untrusted public users from the frontend portals. Internal systems are not directly exposed to the internet.

Portals to API Gateway:
Ensures only authenticated and properly formatted requests reach the backend.

API Gateway to Backend Services:
Prevents direct access to internal business logic and enforces communication rules.

Backend Services to Data Storage:
Only authorized backend services can access databases. Direct database access is blocked.

Backend Services to External Integrations:
Protects communication with the Identity Provider and Job Portals.

Administrative Access:
Separates highly privileged admin/registrar access (VPN or internal network only) from normal user access.

Architecture Diagram

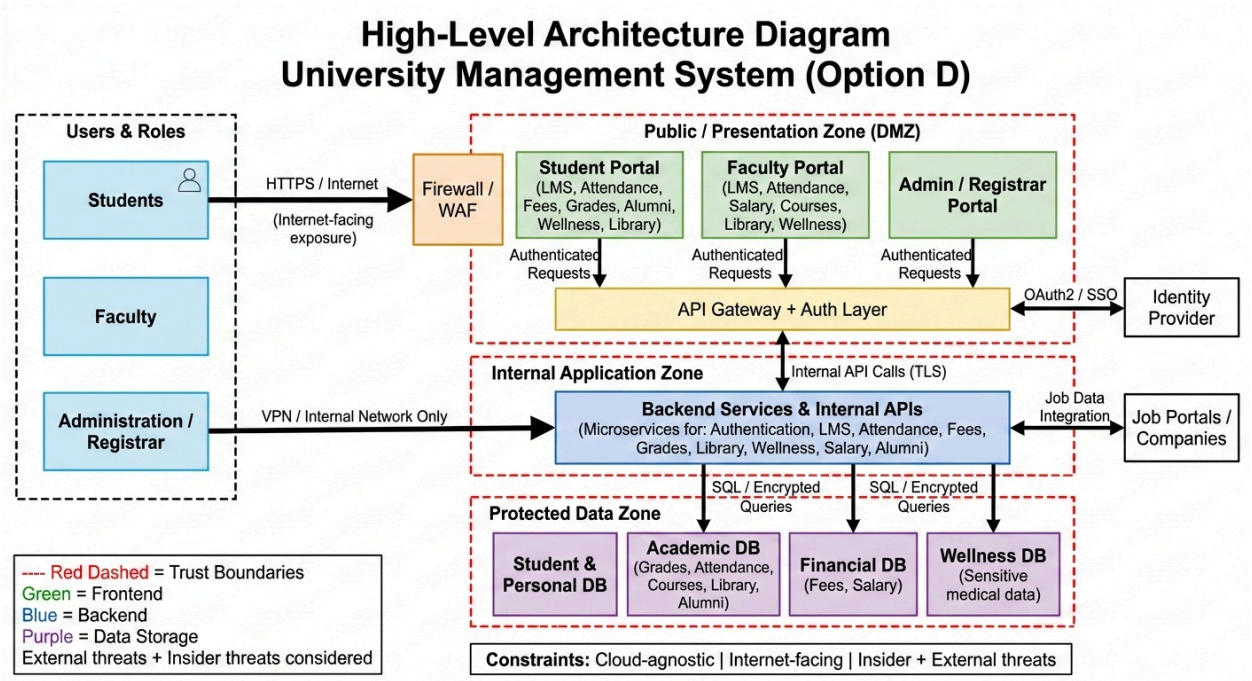

Figure 1: High-Level Architecture Diagram

Asset Inventory

1. Critical Asset Identification

The University Management System processes sensitive academic, financial, and personal data. The following assets are considered critical due to their importance to system operations and data protection requirements.

Asset Inventory Table:

Asset Name	Description
Student Personal & Wellness Data	Student PII including name, CNIC, contact details, address, and health/wellness records

Academic Records	Grades, attendance, course materials, assignments, library usage, alumni records
Financial Data	Student fee payments, transaction history, payroll records
Authentication Credentials	Usernames, passwords, session tokens, access roles
Business Logic	Rules for grading, attendance calculation, fee processing, job portal integration
Audit & Monitoring Logs	System logs recording access, modifications, and transactions
Job Integration Data	Company job postings and student profile data shared with external platforms

2. Security Objectives Mapping

Each asset is evaluated against four security objectives:

- **Confidentiality**: Protection against unauthorized access
- **Integrity**: Protection against unauthorized modification
- **Availability**: Ensuring access when required
- **Accountability**: Ability to trace actions to specific users

Security Objectives Table:

Asset	Confidentiality	Integrity	Availability	Accountability
Student Personal & Wellness Data	High	High	Medium	High
Academic Records	High	Very High	High	High
Financial Data	High	Very High	Medium	High
Authentication Credentials	Very High	High	High	High
Business Logic	Medium	Very High	High	Medium

Audit & Monitoring Logs	High	Very High	Medium	Very High
Job Integration Data	Medium	High	High	Medium

3. Justification:

- **Very High Integrity** is required for Academic Records, Financial Data, Business Logic, and Logs because tampering could severely impact trust and operations.
- **Very High Confidentiality** is required for Authentication Credentials to prevent unauthorized system access.
- **High Accountability** ensures traceability of actions, especially for grades, payments, and system access.
- **Availability** is critical during peak academic and financial periods (exams, fee deadlines, job applications).

Threat Model

1. Threat Modeling Methodology

A structured STRIDE approach was used to identify threats across system components.

STRIDE categories considered:

- Spoofing
- Tampering
- Repudiation
- Information Disclosure
- Denial of Service
- Elevation of Privilege

The analysis covers all required threat areas:

- Authentication
- Authorization
- Data Storage
- API Communication
- Logging & Monitoring
- Administrative Access

Both external attackers (internet-facing threats) and insider threats (students, faculty, administrators) were considered.

2. Threat Model Table:

#	STRIDE Category	Threat Description	Affected Component	Impact	Risk Level
1	Spoofing	Stolen student credentials used to access LMS and grades	Student Portal / Identity Provider	Unauthorized access to personal and academic data	High
2	Tampering	Faculty member alters grades without authorization	Academic Backend / Database	Academic integrity compromised	High
3	Repudiation	Student denies assignment submission	LMS Backend / Audit Logs	Disputes and operational overhead	Medium
4	Information Disclosure	Breach of student wellness records	Wellness Database	Exposure of sensitive health data, legal liability	High
5	Denial of Service	API flooding during exams	API Gateway / Backend Services	System outage during critical period	High
6	Elevation of Privilege	Student gains admin role via role misconfiguration	Admin Portal	Full system compromise	High
7	Spoofing	Forged API token used to submit fake attendance	Internal APIs	Incorrect academic records	Medium
8	Tampering	Modification of fee payment records	Financial Database	Financial loss and fraud	High
9	Repudiation	Administrator denies deleting system logs	Logging System	Investigation failure	Medium
10	Information Disclosure	Excessive faculty access to wellness data	Authorization Layer	Privacy violation	High
11	Denial of Service	Attack on Admin Portal	Admin Access Path	Registrar unable to manage system	Medium

12	Elevation of Privilege	Brute-force attack escalates student to faculty role	Identity Provider	Unauthorized access to payroll and courses	High
13	Tampering	Log manipulation to hide malicious activity	Monitoring System	Reduced detection capability	Medium
14	Information Disclosure	Unencrypted job portal integration leaks student profiles	External API Integration	Exposure of student data	Medium

3. Threat Architecture Diagram:

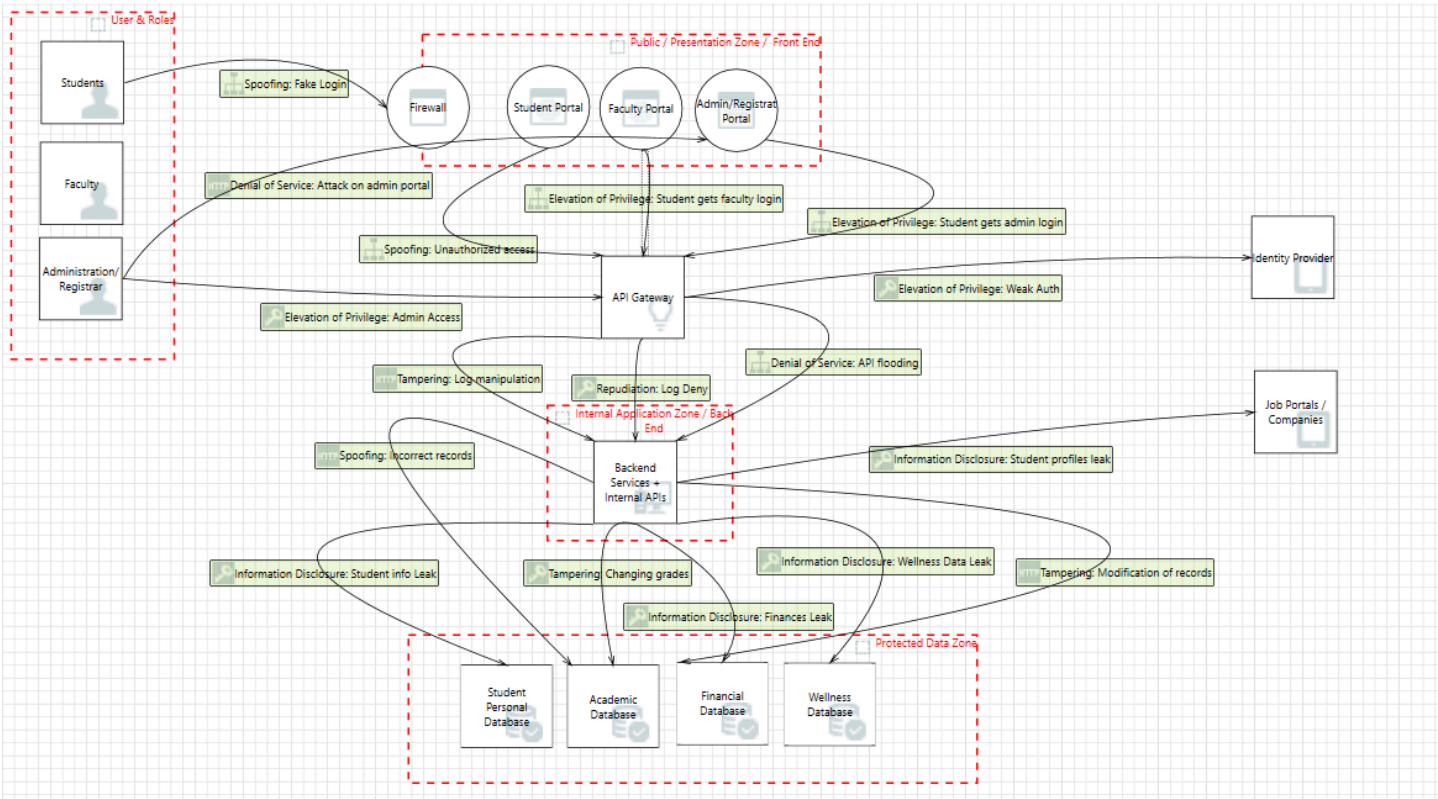

Figure 2: Threat Modeling Diagram using Microsoft Threat Modeling Tool 2016

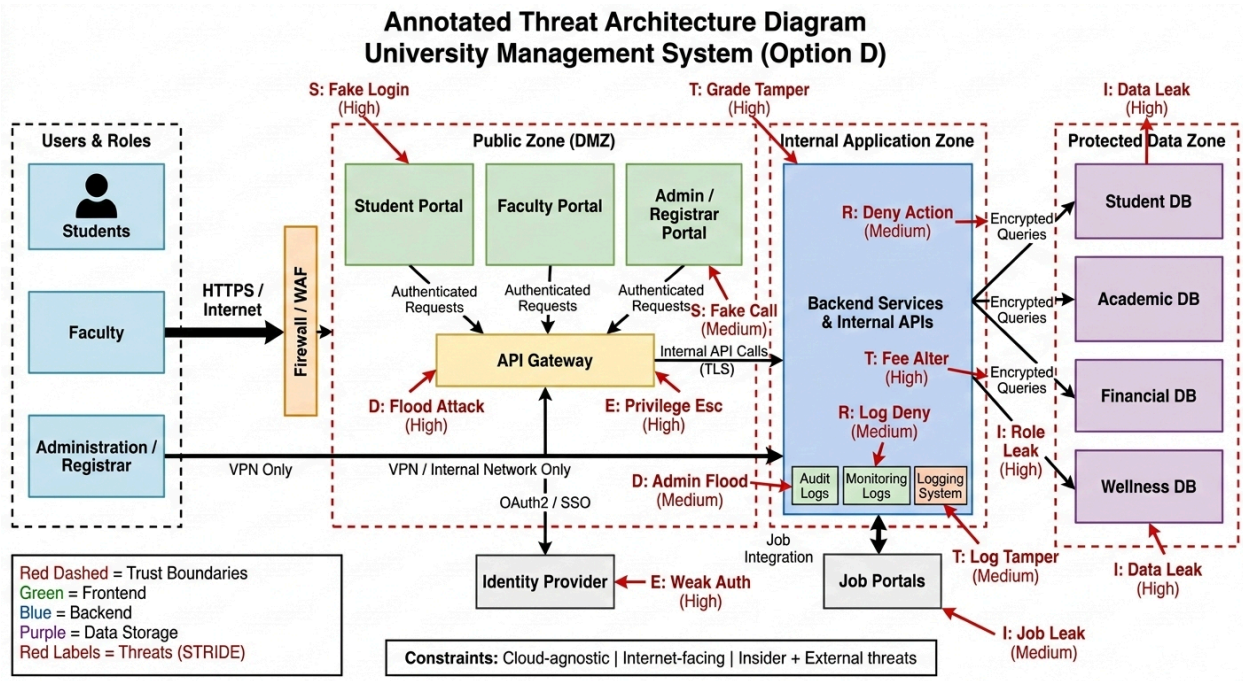

Figure 3: Annotated Threat Architecture Diagram (STRIDE threats shown in red)

4. Risk Assessment Methodology

Risk levels were assigned using qualitative analysis based on:

- **Likelihood**
  - Internet exposure
  - Historical prevalence (e.g., phishing, brute force)
  - Insider access level

- **Impact**
  - Academic integrity damage
  - Financial loss
  - Privacy/legal consequences
  - Operational disruption

Risk Level Criteria

- **High Risk**
  Likely occurrence OR severe impact (financial loss, system takeover, privacy breach, academic fraud).

- **Medium Risk**
  Realistic threat with moderate operational or reputational impact.

- **Low Risk**
  Minimal impact or unlikely scenario (none identified due to internet-facing exposure).

5. Cross-Layer Threat Coverage

Threats were analyzed across three architectural layers:

Application Layer:

- Authentication spoofing
- Role misconfiguration
- API abuse
- Grade tampering

Infrastructure Layer:

- Database tampering
- DoS attacks
- Log manipulation

Organizational Layer:

- Insider grade modification
- Privilege misuse
- Improper access controls

Security Controls

The secure architecture introduces layered architectural controls to mitigate the high and medium risks identified in Task 3.

The design enforces least privilege, strong identity verification, trust boundary protection, and defense-in-depth across application, infrastructure, and administrative layers.

1. Identity and Access Management

Design Controls

- Centralized identity provider for authentication
- Multi-factor authentication for all user roles

- Role-based access control
- Strict separation of student, faculty, and administrator roles
- Short-lived session tokens
- Account lockout after repeated failed login attempts

Purpose: Ensures that only verified users can access the system and restricts actions according to assigned roles.

Risk-Based Justification

Mitigates:

- Spoofing through stolen credentials
- Elevation of privilege
- Unauthorized administrative access

2. Network Segmentation and Trust Boundary Enforcement

Design Controls

- Public portals deployed in a demilitarized network zone separated from internal systems
- Backend services isolated in an internal network zone
- Databases inaccessible directly from public-facing components
- Administrative portal accessible only through a secure management network with restricted access
- Gateway layer enforcing request validation and traffic rate limiting

Purpose: Reduces the attack surface and enforces separation between untrusted external users and trusted internal systems.

Risk-Based Justification

Mitigates:

- Denial of service attacks
- Direct database tampering
- Unauthorized movement between internal systems

If a public-facing component is compromised, segmentation prevents attackers from directly accessing core services and databases.

3. Data Protection Architecture

Design Controls

- Encryption in transit for all communications
- Encryption at rest for all databases
- Field-level encryption for wellness and financial data
- Database access permitted only through authorized backend services

Purpose: Protects confidentiality and integrity of sensitive personal, academic, and financial information.

Risk-Based Justification

Mitigates:

- Information disclosure of health and financial records
- Tampering with academic and payment data

Strong data protection reduces breach impact even if other layers are bypassed.

4. Secrets Management

Design Controls

- Centralized secure storage for secrets
- No credentials stored within application source code
- Automatic rotation of credentials and keys
- Access to secrets restricted according to user role

Purpose: Protects authentication tokens, database credentials, and integration keys from unauthorized exposure.

Risk-Based Justification

Mitigates:

- Spoofing of backend services
- Privilege escalation using leaked credentials
- Compromise of internal services

Protecting secrets prevents attackers from bypassing authentication and authorization controls.

5. Monitoring, Logging, and Accountability

Design Controls

- Centralized logging infrastructure

- Tamper-resistant audit logs
- Real-time alerts for:
    - Failed login attempts
    - Role changes
    - Grade modifications
    - Log deletion attempts
- Logical separation between application services and logging systems

Purpose: Ensures traceability of user actions and enables rapid detection of suspicious activity.

Risk-Based Justification

Mitigates:

- Repudiation threats
- Insider grade manipulation
- Log tampering

6. Secure Deployment and Infrastructure Hardening

Design Controls

- Services deployed with least privilege permissions
- Minimal network exposure with only necessary ports open
- Regular security patch management
- Automated vulnerability scanning before deployment
- Traffic throttling and rate limiting at the gateway layer

Purpose: Reduces exploitability of infrastructure components and limits abuse of system resources.

Risk-Based Justification

Mitigates:

- Denial of service attacks
- Exploitation of outdated software
- System disruption during high usage periods

Secure Architecture Diagram:

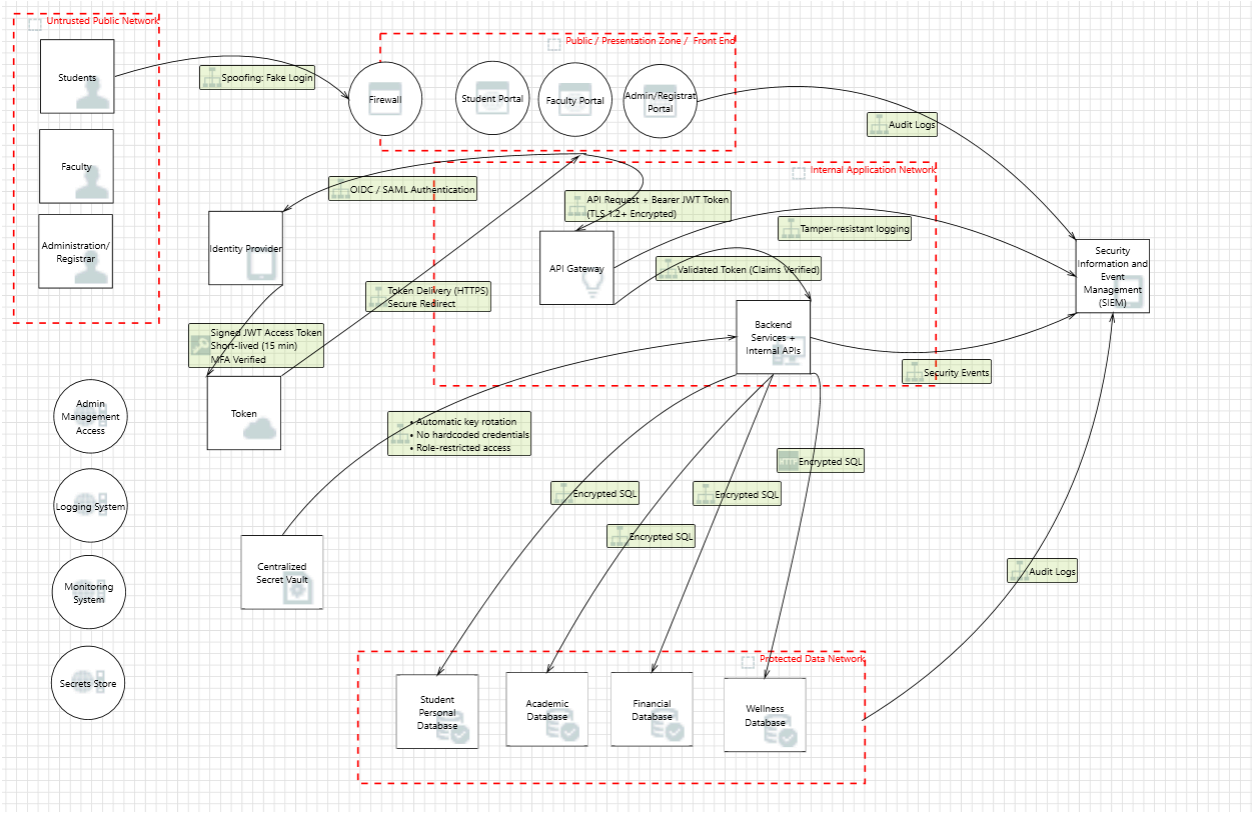

Figure 4: Secure Architecture Diagram using Microsoft Threat Modeling Tool 2016

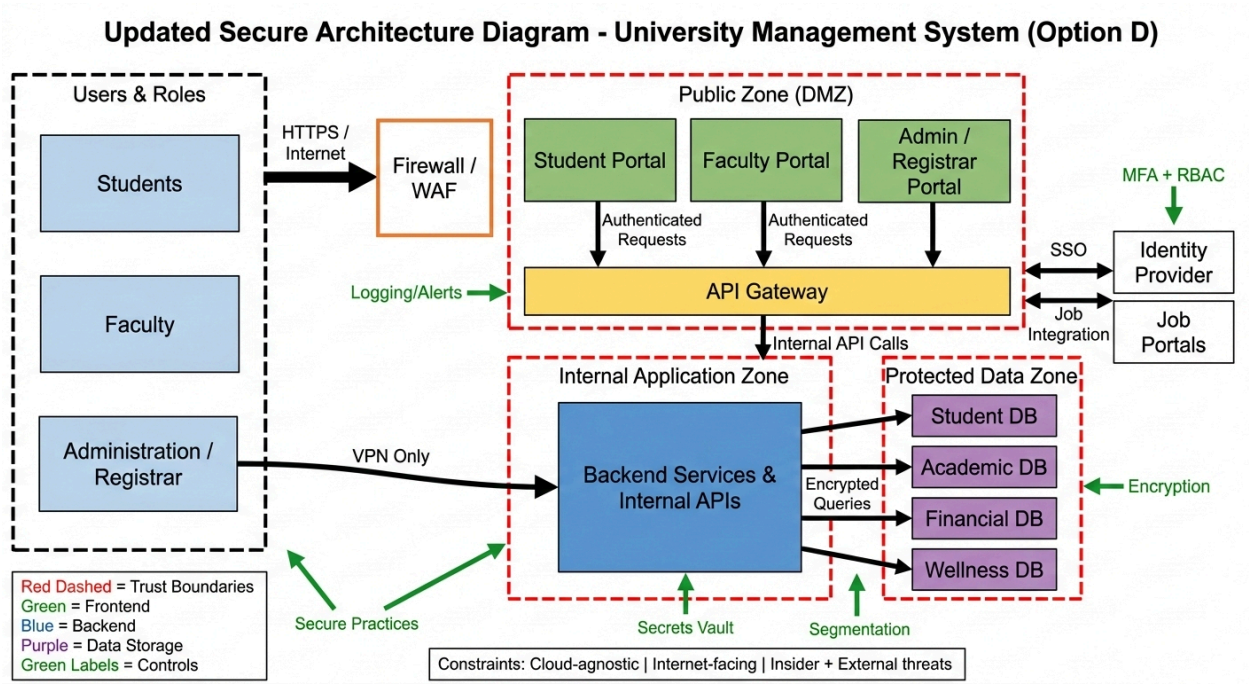

Figure 5: Annotated Secure Architecture Diagram (shown in green)

Defense-in-Depth:

Security is implemented through multiple protective layers:

1. Identity verification
2. Role enforcement
3. Network isolation
4. Data encryption
5. Secrets protection
6. Continuous monitoring

This layered architecture ensures that failure of a single control does not result in total system compromise.

Residual Risk

1. Risk Treatment Approach

For each high-risk threat, one of the following was applied:

- Mitigate: Reduce the risk using a security control.
- Transfer: Shift the risk to another party, such as insurance for downtime.
- Accept: Live with the risk if it is low likelihood or too expensive to fix.
- Avoid: Do not implement a risky feature.

All mitigations use the controls from Task 4, including identity and access management, network separation, data protection, secret management, monitoring, and secure deployment.

2. Risk Treatment Table:

Threat	Treatment	How / Control Used	Justification
Spoofing : Student login credentials stolen	Mitigate	Identity and Access Management with multi-factor verification and role-based access	Strong login checks prevent unauthorized access, reducing risk from common phishing
Tampering : Changing grades	Mitigate	Network separation + Logging	Keeps insiders from directly changing grades and logs all changes for accountability

Information Disclosure: Leak of student health data	Mitigate	Data protection with encryption	Encrypting data prevents outsiders from reading sensitive health records
Denial of Service : System flood during exams	Mitigate	Secure deployment + Network separation	Firewalls and traffic limits stop overloads and keep the system available
Elevation of Privilege : Student becomes administrator	Mitigate	Identity and Access Management + Restricted admin access	Strong roles and secure admin network prevent unauthorized privilege escalation
Tampering : Altering fee payments	Mitigate	Data protection + Secret management	Encryption and secure storage protect financial data from tampering
Information Disclosure: Faculty sees data they should not	Mitigate	Identity and Access Management with role-based access	Strict role assignments prevent accidental or malicious data exposure
Elevation of Privilege : Weak password allows student to act as faculty	Mitigate	Identity and Access Management with multi-factor verification	Requires strong authentication, reducing brute-force attacks

3. Residual Risk Explanation

Even after these treatments, some small risks remain:

1. Insider attacks: A teacher or administrator could still try to tamper with records if monitoring fails. This is accepted because complete prevention is too costly, but most risk is reduced by logging and role separation.

2. Large-scale denial of service: An extremely large attack could still disrupt the system. This risk is transferred to insurance for downtime costs, since some internet-facing exposure cannot be fully prevented.

3. Human error with passwords: Users might ignore multi-factor verification or choose weak passwords. This is accepted as a residual risk but reduced by training and enforcing strong password rules.

Overall Residual Risk: Low to medium. Most high-risk threats are mitigated by layered defenses such as encryption, network separation, strict roles, and monitoring.

Assumptions and Limitations

Following are the assumptions and limitations of the system:

Assumptions:

- The Identity Provider is secure and properly configured.
- Servers, databases, and network systems are regularly updated and patched.
- All system communication uses strong encryption.
- Passwords, tokens, and secret keys are stored securely.
- External integrations use secure and authenticated connections.

Limitations:

- Risk levels are based on general judgment, not detailed calculations.
- A trusted insider may still misuse access before detection.
- Very advanced or new attack methods may not be covered.
- Extremely large DDoS attacks may still impact availability.
- Security of third-party systems is outside direct control.